Annex27 — Informatiebeveiliging & scheiding BSI-auditwerk

Onderneming: Annex27 (KBO/BCE 1006.203.170), eenmanszaak, Joseph Smeetslaan 1 bus 13630, 3630 Maasmechelen (BE) **Verantwoordelijke:** eigenaar (tevens enige medewerker en auditor) **Doel van dit document:** aantonen dat de technische en organisatorische maatregelen voldoen aan (a) de BSI Contractor Agreement, met name clausule 4 (equipment/encryptie), 8 (vertrouwelijkheid), 10 (IP) en 12 (persoonsgegevens/verwerker), en (b) de verklaringen in het GF077-formulier. Tegelijk is dit het mini-ISMS van Annex27 als eenmanszaak. **Versie:** 1.0 · **Reviewcyclus:** jaarlijks of bij wijziging van de BSI IT-richtlijn.

DEEL A — Scheidingsopzet: BSI-auditwerk ↔ Annex27-platform

A.1 Twee petten, twee datadomeinen

Je opereert in twee rollen die strikt gescheiden blijven:

	Rol 1 — Annex27 (Supplier/SaaS)	**Rol 2 — BSI-contractor (auditor)**
Wat	Compliance-SaaS voor MKB (gap-analyse, NIS2, beleidspakket)	ISO 27001-audits voor BSI-klanten
Klant	Eigen MKB-klanten van Annex27	BSI (en via BSI hun auditklanten)
Systemen	Hostnet, Supabase (eu-west-1), Mollie, Resend, eigen AI-pipeline	**Uitsluitend BSI-systemen**: Point Global, SFDC (Salesforce), BSI-e-mail
Data-eigenaar	Annex27 / de MKB-klant	**BSI / de auditklant** (clausule 10: IP van rapporten = BSI/klant)

A.2 Kernregel (de "firewall")

> **BSI-auditdata komt NOOIT op het Annex27-platform.**

Reden: Annex27's cloudleveranciers (Supabase, de AI-pipeline met Mistral/OpenAI, Resend, Mollie) zouden dan **niet-geautoriseerde sub-verwerkers** van BSI-data zijn. Clausule 12 verbiedt het inschakelen van een sub-verwerker zonder **voorafgaande schriftelijke toestemming van BSI**. Bovendien schendt het de vertrouwelijkheid (clausule 8) en de IP-eigendom (clausule 10).

A.3 Waar BSI-data WEL mag staan

- **Point Global** en **SFDC** — de aangewezen BSI-documentopslag; hier upload je alle auditinformatie (documenten, records, foto's, auditnotities, rapporten, deelnemersinfo, BSI-lesmateriaal).
- **BSI-e-mail** — voor álle BSI-gerelateerde communicatie met klanten, scheme owners en BSI-medewerkers, met de **BSI-goedgekeurde footer**.

- **Tijdelijk lokaal op je (versleutelde) laptop** — alleen tijdens de audit, en **verwijderd zodra je naar Point Global/SFDC hebt geüpload**.

A.4 Waar BSI-data NOOIT mag komen

- ✕ Annex27-Supabase (database, storage buckets, evidence-upload)
- ✕ De Annex27 AI-pipeline (generate-report, evaluate-evidence, generate-findings-draft) — die stuurt data naar externe LLM's = sub-verwerker
- ✕ Resend (Annex27's mailprovider) of het `@annex27.nl`-mailadres
- ✕ Mollie, Google Analytics, of enige andere Annex27-integratie
- ✕ Persoonlijke opslag: privé-cloud (Google Drive/iCloud/Dropbox), privé-mail (`raoul_haas@live.nl`), USB-sticks zonder versleuteling, telefoon-galerij
- ✕ Het GitHub-repo van Annex27 (public/private) of enige back-up daarvan

A.5 E-mailscheiding

- **BSI-werk** → BSI-mailadres + BSI-footer. Verplicht per GF077.
- **Annex27-business** → `@annex27.nl`.
- Kruis nooit: geen BSI-klant mailen vanaf annex27, geen Annex27-klant vanaf BSI-mail. Geen doorsturen van BSI-mail naar privé/annex27.

A.6 Laptop: gedeeld toestel of apart

Clausule 4 zegt dat Annex27 (de Supplier) je een laptop levert voor de Services. Twee opties:

- **Voorkeur:** een **apart, dedicated toestel** (of aparte Windows-gebruiker met eigen versleutelde profiel) uitsluitend voor BSI-werk. Schoonste scheiding, minste kans op vermenging.
- **Minimaal aanvaardbaar:** één laptop, mits (1) volledige schijfversleuteling aan (BitLocker, zie Deel B), (2) BSI-data alleen in BSI-cloud en lokaal direct opgeruimd, (3) aparte browserprofielen/mapstructuur voor BSI vs Annex27.

> **Beslissing die jij moet maken:** dedicated BSI-toestel of gescheiden profiel op één laptop. Leg de keuze hier vast: _____

A.7 Einde opdracht / contract

- Per SOW: klantdata na upload lokaal verwijderen.
- Bij einde Contractor Agreement: **binnen 14 kalenderdagen** alle BSI-data onherstelbaar verwijderen, zonder kopieën in welk formaat dan ook (clausule 13.4).

DEEL B — Mini-ISMS Annex27 (eenmanszaak)

B.1 Scope

Alle informatie en middelen waarmee Annex27 werkt: de laptop(s), telefoon, online accounts, en zowel Annex27-klantdata als (gescheiden) BSI-auditdata. Eén persoon vervult alle rollen: eigenaar, beheerder, auditor, verwerkingsverantwoordelijke.

B.2 Middelen-inventaris (vul in en houd actueel)

Middel	Detail	Versleuteld?	MFA?
Laptop (werk)	Windows 11 Pro	BitLocker: ja/nee	n.v.t.
Telefoon		schermvergrendeling + encryptie	ja/nee
Externe schijf / USB		BitLocker To Go: ja/nee	n.v.t.
BSI-account (Point Global/SFDC/mail)		(door BSI beheerd)	ja
Annex27-Supabase		(server-side)	ja
Wachtwoordmanager			ja

B.3 Toegangsbeveiliging

- **Wachtwoordmanager** voor alle accounts; unieke, sterke wachtwoorden. Geen hergebruik.
- **MFA (2FA)** aan op alles wat het ondersteunt: BSI-account, e-mail, Supabase, GitHub, Mollie, hosting.
- Schermvergrendeling met sterke pincode/wachtwoord op laptop én telefoon; auto-lock ≤ 5 min.

B.4 Versleuteling — BitLocker-onderbouwing (voldoet aan clausule 4 + GF077)

GF077-verklaring die je afgeeft: *"I confirm that I have encryption software loaded onto my laptop."*
Onderbouwing:

- **Volledige-schijfversleuteling** op de systeemschijf met **BitLocker** (Windows 11 Pro bevat volledige BitLocker, niet alleen "apparaatversleuteling").
- **Controle** (voer zelf uit in PowerShell/CMD):

  ```
  manage-bde -status C:
  ```

  Vereist resultaat: **Conversion Status: Fully Encrypted** en **Protection Status: Protection On**.
- **Aanzetten** als het uit staat: Instellingen → Privacy en beveiliging → Apparaatversleuteling/BitLocker, óf Configuratiescherm → BitLocker-stationsversleuteling → *BitLocker inschakelen* voor C:.
- **Herstelsleutel (recovery key):** bewaar veilig en **niet op dezelfde laptop**. Aanbevolen: in je wachtwoordmanager én een geprinte kopie op een fysiek veilige plek. Niet op een onversleutelde USB of in je annex27-cloud.
- **Externe dragers:** elke USB/externe schijf die werkdata raakt → **BitLocker To Go**.
- **Telefoon:** moderne Android/iPhone zijn standaard versleuteld mits een sterke schermvergrendeling is ingesteld — controleer dat.
- **Volg de BSI IT-richtlijn:** als BSI een specifieke standaard of tool voorschrijft (BSI IT Policies for Contractors), volg die, ook als BitLocker al aanstaat.

B.5 Data-classificatie & bewaartermijnen

Klasse	Voorbeeld	Waar	Bewaartermijn

BSI-auditdata (vertrouwelijk, IP=BSI)	auditnotities, rapporten, klantbewijs	Point Global/SFDC; lokaal alleen tijdelijk	lokaal: direct na upload wissen · contract-einde: ≤14 dagen onherstelbaar
Annex27-klantdata	gap-analyse, evidence	Supabase (RLS)	per Annex27-retentiebeleid (bv. 90 dagen na oplevering)
Persoonlijk/ administratief	facturen, contracten	eigen boekhouding	wettelijke bewaarplicht (BE: 7 jaar boekhouding)

B.6 Back-up & herstel (clausule 12: beschikbaarheid + herstelvermogen)

- **Annex27-data:** Supabase-back-ups (bestaand); periodiek testen dat een restore werkt.
- **BSI-data:** géén eigen back-up maken — de bron is Point Global/SFDC (BSI's systeem). Jij houdt lokaal niets structureel bij.
- **Eigen administratie:** versleutelde back-up (bv. BitLocker-schijf of versleutelde cloud) van boekhouding/contracten.
- **Herstel-test:** minstens 1x per jaar een testrestore doen en de datum hier noteren: _____

B.7 Datalek- / incidentprocedure

Bij (vermoeden van) verlies, diefstal, ongeoorloofde toegang of lek:

1. **Onmiddellijk indammen** — toestel loskoppelen, wachtwoorden roteren, toegang intrekken.
2. **BSI informeren zonder onnodige vertraging** (clausule 12). Bij een datasubject-verzoek of klacht over BSI-data: **binnen 48 uur** aan BSI melden.
3. **Bij persoonsgegevens van Annex27-klanten:** beoordeel meldplicht aan de Gegevensbeschermingsautoriteit (BE) / AP (NL) — in de regel binnen 72 uur indien meldingsplichtig.
4. **Vastleggen:** wat, wanneer, welke data, welke actie. Bewaar het incidentlog.

- Contact BSI-incident: _____ (invullen zodra BSI dit aanlevert)

B.8 Acceptabel gebruik / clean device

- BSI-werk alleen op het aangewezen (versleutelde) toestel/profiel.
- Geen BSI-data via privé-mail, privé-cloud, chat-apps of onversleutelde USB.
- Software up-to-date houden (OS, browser, antivirus). Automatische updates aan.
- Geen niet-vertrouwde software installeren op het werktoestel.

B.9 Periodieke controle (jaarlijkse "directiebeoordeling" voor één persoon)

Eén keer per jaar (en bij grote wijzigingen) doorloop je deze lijst en teken je af:

- [ ] BitLocker nog "Protection On" op alle toestellen (`manage-bde -status`)
- [ ] MFA nog actief op alle accounts
- [ ] Wachtwoordmanager up-to-date, geen zwakke/hergebruikte wachtwoorden
- [ ] BSI-data niet aangetroffen op het Annex27-platform of privé-opslag
- [ ] Restore-test uitgevoerd
- [ ] Verzekering (BAV + BA uitbating) nog geldig

- [ ] BSI IT-richtlijn opnieuw gelezen; wijzigingen doorgevoerd
- Datum review: _____ · Uitgevoerd door: eigenaar

Bijlage — Mapping naar BSI-eisen (bewijs-index)

BSI-eis	Waar afgedekt
Clausule 4 — laptop met encryptie per BSI IT-richtlijn	B.4
Clausule 8 — vertrouwelijkheid (5 jr)	A.2, A.4, B.8
Clausule 10 — IP van rapporten bij BSI/klant	A.1, A.3, A.7
Clausule 12 — verwerker: encryptie, vertrouwelijkheid, herstel, testen, geen sub-verwerker, breach/48u	A.2, B.4, B.6, B.7
Clausule 13.4 — 14-dagen verwijdering bij einde	A.7, B.5
GF077 — encryptie op laptop	B.4
GF077 — alleen BSI-e-mail + footer	A.5
GF077 — upload naar Point Global/SFDC + wissen van eigen apparaten	A.3, A.4, B.5